SOP For Risk Advisory

This Standard Operating Procedure (SOP) outlines the step-by-step process for creating, managing, and resolving advisories within the ASPIA system, ensuring proper documentation, notifications, and status updates.

Objective:
To enable users to create and manage risk advisories in the system with all relevant metadata, including severity, status, CVE, description, mitigation strategy, and attachments.

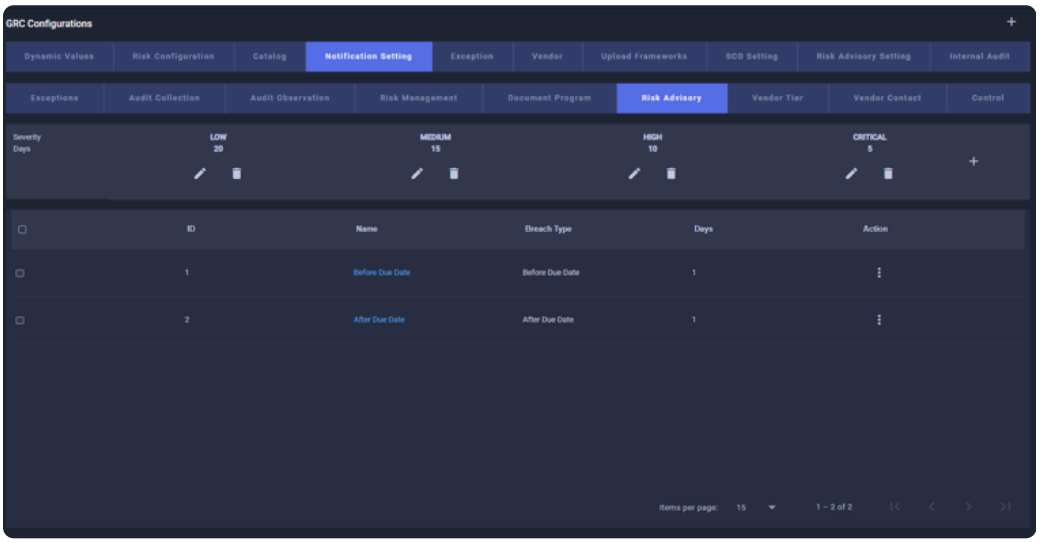
Step 1: Access the ASPIA Platform

- **Action:** Log in to the ASPIA platform using your credentials.

Step 2: Configure Risk Advisory Notifications

Before creating advisories, configure the notification and email settings.

1. **Go to: GRC Configuration → Notification Settings → Risk Advisory**
   - Add severity levels and define the number of days for closure.
   - Configure Before Due Date and After Due Date notifications.



Manager Level Escalation:-

Navigation:
Go to **GRC Configuration > Notification Setting > Risk Advisory** and select any notification rule (Before or After).
While configuring the notification, you can set the **Manager Levels** value.

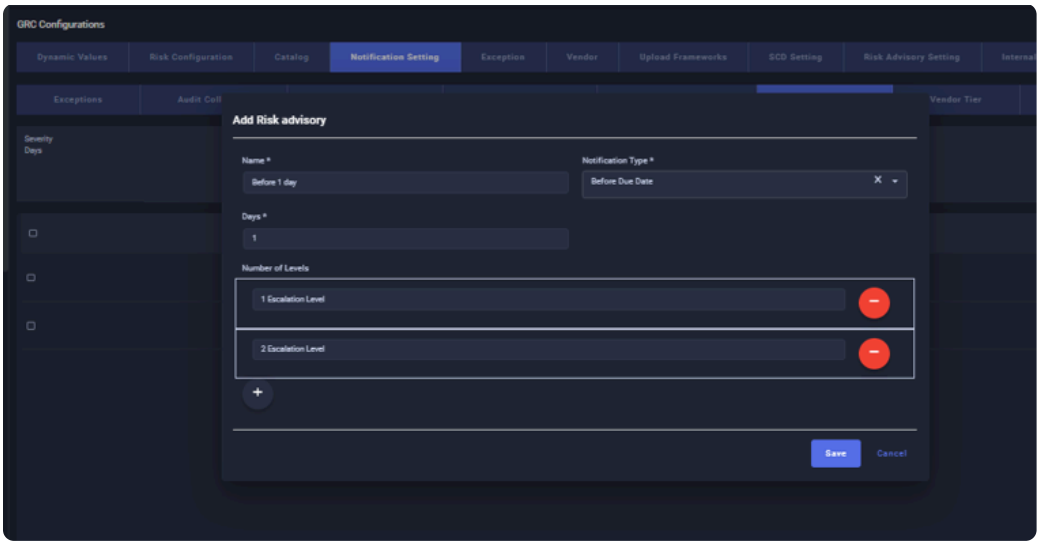
Usage:

Manager Level Escalation enables the system to automatically forward notifications to the supervisory hierarchy above the responsible user. This ensures visibility, accountability, and timely follow-up on advisory activities.

Depending on the value set in **Manager Levels**, notifications will be escalated to:

- Level **1** → Sends notification to the user's **direct manager**
- Level **2** → Sends notification to the **manager** and the **manager's manager**
- Level **3+** → Escalates further up the chain, sending notifications to the next-level managers for the specified number of levels

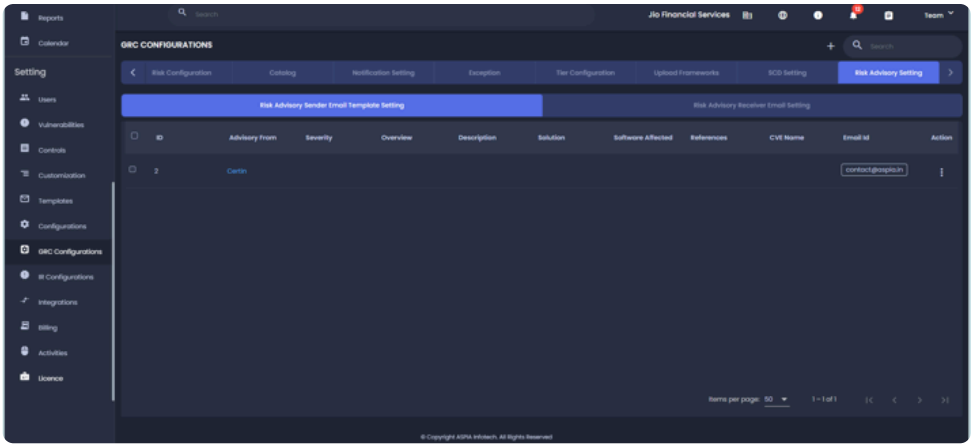
This ensures that not only the responsible user but also their supervisory chain is informed about advisory deadlines, breaches, or required follow-ups.



Step 3: Configure Auto Advisory Sync

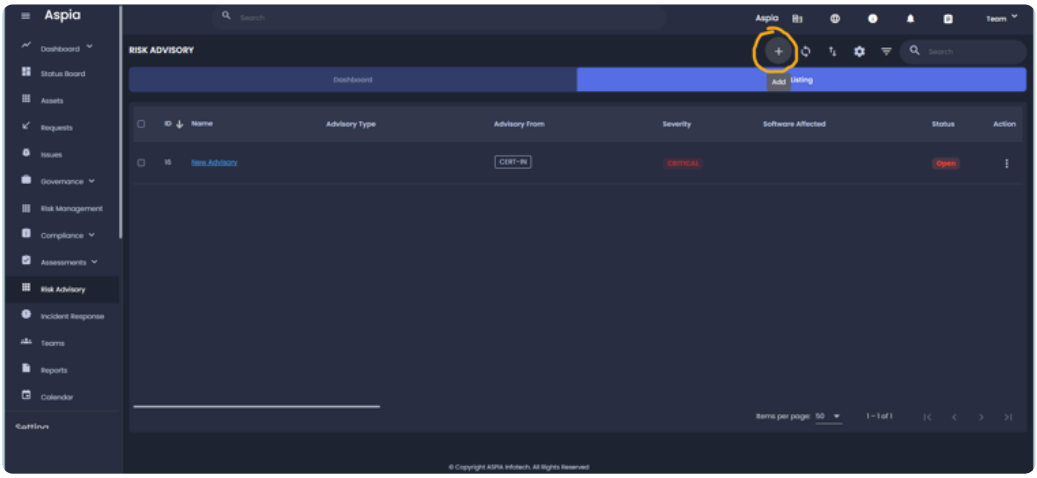
Go to: *GRC Configuration → Risk Advisory Settings*

- **Risk Advisory Sender Email Template Setting**
  - Define the external sources from which advisories will be received (e.g., CERT-In, RBI, or other regulatory authorities).
- **Risk Advisory Receiver Email Template Setting**
  - Configure the designated internal mailbox (user email account) where advisories from the defined senders are received.
  - ASPIA will automatically sync advisories from this mailbox into the platform, creating advisories in the system without manual entry.



Step 4: Create a New Risk Advisory Manually

- **Action:** Go to the **"Risk Advisory"** module.
  Click on the **+** icon to create a new risk advisory .

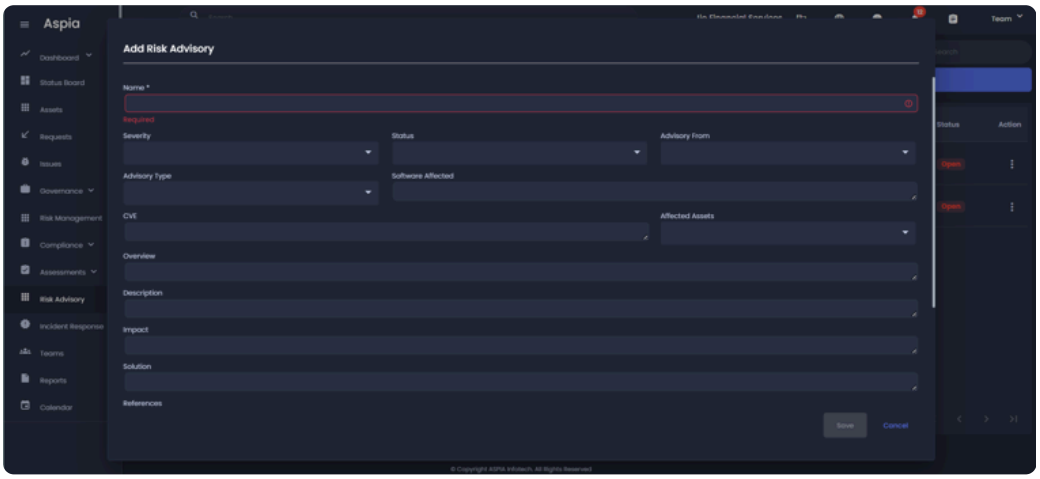


- **Form Completion:**

Field Name	Type	Required	Description
Name	Text	Yes	Title of the risk advisory
Severity	Dropdown	No	Risk severity level (Low, Medium, High, Critical)
Status	Dropdown	No	Advisory status (Open, In Progress, Closed, etc.)

Advisory From	Dropdown	No	Source of the advisory
Advisory Type	Dropdown	No	Category/type of the advisory
Software Affected	Text	No	Name of affected software
CVE	Text	No	Common Vulnerabilities and Exposures ID
Affected Assets	Multi-select	No	Assets impacted by this risk advisory
Overview	Text Area	No	Brief overview of the advisory
Description	Text Area	No	Detailed description of the risk
Impact	Text Area	No	Potential consequences or damages
Solution	Text Area	No	Suggested solution or mitigation strategy
References	Text Area	No	External references (URLs, reports, etc.)

Attachment	File Upload	No	Upload supporting files (PDFs, images, etc.)
Remark	Text	No	Internal note or comment
Responsibility	Radio (User/Team)	Yes	Responsible entity (user or team)
User / Team Select	Dropdown	If applicable	Responsible user or team depending on selection
Tags	Text (comma-separated)	No	Classification or searchable tags



Save Risk Advisory

- **Action**: After completing the form, click on the "Save" button.
- **Notification**: ASPIA sends an automated email notification to the Responsible User.

Step 5: Assign and Work on the Advisory

Purpose: To allow the responsible person to take ownership and resolve the advisory before the due date.

Action:

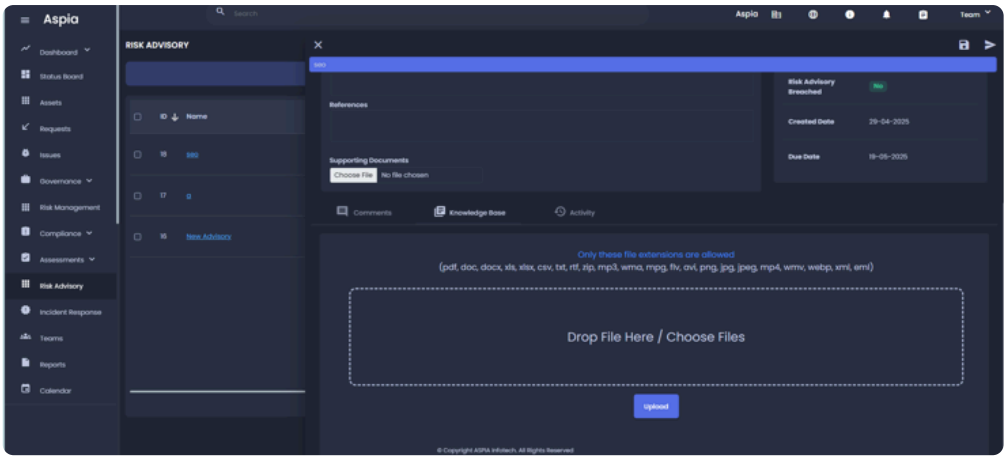
- The responsible user logs in to ASPIA and accesses the advisory.
- Update the advisory status to **In Progress** while working on it.
- If the advisory is **not applicable**, the user can update the status to **N/A**.

Step 6: Upload Closure Evidence/Comment

Purpose: To provide supporting evidence before closure.

Steps:

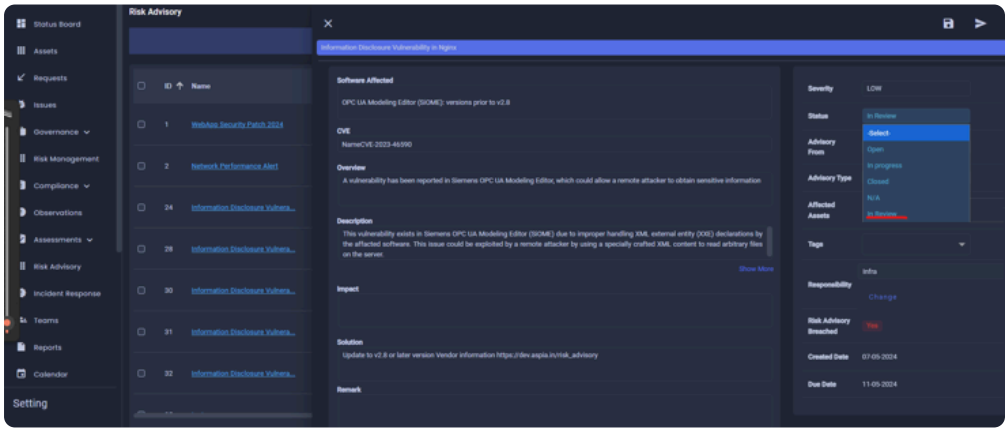
1. **Upload Documents**
   - Within the advisory, select the *Knowledge Base* option.
   - Browse and attach required supporting documents.



2. **Step 2: Status Update**

   The status will automatically update to **In Review** once the evidence is provided in the Knowledge Base.

3. **Notification:** ASPIA sends an automated email to users with **Mark Risk Advisory Closed** permission.



Step 7: Closure of Risk Advisory

- A user with **Mark Risk Advisory Closed** permission reviews the advisory and either:
  - **Closes** the advisory, or
  - **Reopens** it if further action is required.

Notification: ASPIA sends an automated email to the responsible user confirming whether the advisory is closed or reopened.